

BHARAT VIKAS BANK

Data Protection Policy

India Operations — Comprehensive Governance Framework

Document Classification	INTERNAL — RESTRICTED
Policy Owner	Chief Compliance Officer & Data Protection Officer
Version	4.0
Effective Date	1 April 2026
Next Review Date	31 March 2027
Approved By	Board Risk & Compliance Committee
Reference	BVB/COMP/DPP/IND/2026/04

This document contains confidential and proprietary information of Bharat Vikas Bank. It is intended solely for authorised personnel and must not be shared externally without prior written approval from the Chief Compliance Officer.

Table of Contents

- 1. Purpose**
- 2. Scope**
 - 2.1 Geographic Scope
 - 2.2 Functional Scope
 - 2.3 Personnel Scope
- 3. Definitions**
- 4. Regulatory Framework**
 - 4.1 Digital Personal Data Protection (DPDP) Act, 2023
 - 4.2 RBI Guidelines and Master Directions
 - 4.3 SEBI and IRDAI Compliance
 - 4.4 IT Act, 2000 and IT (Amendment) Act, 2008
 - 4.5 Aadhaar and PMLA Compliance
- 5. Data Classification**
- 6. Roles and Responsibilities**
 - 6.1 Board and Senior Management
 - 6.2 Chief Compliance Officer
 - 6.3 Data Protection Officer
 - 6.4 Compliance Officers
 - 6.5 Information Security Team
 - 6.6 Platform Administrators
 - 6.7 Architects and Technology Design Teams
 - 6.8 Data Engineers
 - 6.9 AI Engineers and Analytics Teams
 - 6.10 Developers
 - 6.11 Auditors
 - 6.12 Third-Party Service Providers
- 7. Data Protection Principles**
- 8. Sensitive Data Handling**
 - 8.1 Identity Information
 - 8.2 Customer Personal Information
 - 8.3 Financial Information
 - 8.4 Authentication and Credential Information
 - 8.5 Health and Medical Information
- 9. Access Control and Need-to-Know**
- 10. Data Minimisation and Purpose Limitation**
- 11. Cross-Border Data Transfers**
- 12. AI Governance and Responsible Use of Technology**
- 13. Monitoring, Audit, and Oversight**
- 14. Incident Management and Breach Notification**
- 15. Third-Party and Vendor Management**
- 16. Regulatory Compliance References**

- 17. Exceptions and Deviations
- 18. Policy Review and Governance
 - A. Appendix A — Data Classification Reference Table
 - B. Appendix B — Regulatory Framework Comparison
 - C. Appendix C — Glossary of Regulatory Bodies and Acts

1. Purpose

This policy establishes the enterprise-wide framework of Bharat Vikas Bank (the "Bank") for the protection of personal data, sensitive financial information, and other regulated data categories across all its operations in India. It reflects the Bank's commitment to responsible data stewardship, regulatory compliance, and the fundamental privacy rights of its customers, employees, and business partners.

India's data protection landscape has undergone a landmark transformation with the enactment of the **Digital Personal Data Protection (DPDP) Act, 2023**, which establishes a comprehensive legal framework for the processing of digital personal data. This policy aligns with the DPDP Act, relevant Reserve Bank of India (RBI) guidelines, the Information Technology Act, 2000, and internationally recognised standards including ISO/IEC 27001, ISO/IEC 42001, PCI DSS, and the NIST AI Risk Management Framework.

This policy ensures that all personnel — whether processing customer Aadhaar numbers, PAN cards, bank account information, UPI IDs, or operating technology platforms that handle sensitive financial and personal data — do so in a lawful, transparent, and accountable manner consistent with the Bank's obligations under Indian law.

■ *This policy is mandatory for all Bank personnel and third-party service providers. Non-compliance may result in disciplinary action and regulatory sanctions.*

2. Scope

2.1 Geographic Scope

This policy applies to:

- All branches, offices, and subsidiaries of the Bank operating within India.
- All processing of personal data of Indian residents, regardless of where such processing occurs.
- Digital banking platforms, mobile applications, and technology systems operated by or on behalf of the Bank.
- All cloud environments, data centres, and co-location facilities processing Bank customer data.

2.2 Functional Scope

This policy applies to all business functions that collect, process, store, share, or dispose of personal or sensitive data, including:

- Retail, SME, and corporate banking operations
- Credit, lending, and loan origination divisions
- Treasury, trade finance, and capital markets
- Human resources, payroll, and employee benefits
- Information technology, digital banking, and core banking systems
- Risk, compliance, legal, and internal audit functions
- Marketing, customer engagement, and analytics
- Third-party and outsourced operations

2.3 Personnel Scope

This policy is binding on:

- All permanent, contractual, and seconded employees of the Bank
- Technology teams including developers, data engineers, AI engineers, and platform administrators
- Compliance officers, auditors, and risk managers
- Vendors, outsourced service providers, and third-party data processors acting on behalf of the Bank
- Interns and consultants with access to Bank systems or customer data

3. Definitions

Term	Definition
Personal Data	Any data about an individual who is identifiable by or in relation to such data. This includes names, Aadhaar numbers, PAN numbers, contact details, financial account information, biometrics, and any combination of data that can identify a person.
Sensitive Personal Data (SPD)	A subset of personal data carrying higher risk of harm if disclosed without authorisation. Under Indian law and RBI guidelines, this includes financial credentials, authentication information, health records, biometric data, and government-issued identity numbers.
Data Fiduciary	An entity that determines the purpose and means of processing personal data. Under the DPDP Act, 2023, the Bank acts as a Data Fiduciary in respect of customer and employee data.
Data Processor	An entity that processes personal data on behalf of the Data Fiduciary. Vendors and technology service providers typically act as Data Processors.
Data Principal	The individual to whom the personal data relates — primarily customers, employees, and counterparties. Under the DPDP Act, the Data Principal has specific enforceable rights.
Consent Manager	A registered entity under the DPDP Act, 2023 through which Data Principals may give, manage, review, and withdraw their consent.
Data Protection Officer (DPO)	The designated individual responsible for overseeing the Bank's compliance with the DPDP Act, 2023, RBI data governance guidelines, and this policy. The DPO is a mandatory appointment for Significant Data Fiduciaries.
Data Masking	The practice of obscuring or replacing sensitive data fields with non-sensitive equivalents in environments where full data access is not required, such as development or testing environments.
Data Redaction	The permanent removal or concealment of specific sensitive information from documents or records before they are shared or disclosed externally.
Encryption	The transformation of data into an unreadable format using cryptographic methods, ensuring that only authorised parties holding the decryption key can access the information.
Purpose Limitation	The principle that personal data collected for a defined purpose must not be used for any other purpose without a new lawful basis or fresh consent from the Data Principal.
Data Localisation	The requirement under applicable RBI guidelines that certain categories of payment and customer data must be stored only within Indian territory.

4. Regulatory Framework

The Bank's data protection obligations in India arise from a layered regulatory framework encompassing statute law, central bank guidelines, and sector-specific regulations. All business and technology teams must be familiar with the requirements applicable to their function.

4.1 Digital Personal Data Protection (DPDP) Act, 2023

The **Digital Personal Data Protection Act, 2023** (DPDP Act) is India's landmark federal legislation governing the processing of digital personal data. It came into force following Presidential assent in August 2023 and represents the most comprehensive data privacy framework India has enacted to date.

Key Obligations Under the DPDP Act:

- **Lawful Basis and Consent:** The Bank may process personal data of a Data Principal only with their freely given, specific, informed, and unambiguous consent, or for certain legitimate uses specified in the Act (such as compliance with legal obligations, employment processing, or medical emergencies). Consent must be obtained through a clear and plain-language notice that explains the purpose of data collection.
- **Notice Requirements:** Before collecting personal data — including customer names, mobile numbers, email addresses, date of birth, or Aadhaar numbers — the Bank must provide a notice describing the data to be collected and the purpose for which it will be processed.
- **Rights of Data Principals:** Customers and employees have the right to access their data, correct inaccuracies, seek erasure of data that is no longer necessary, obtain a portable copy of their data, nominate a representative in the event of death or incapacity, and raise grievances directly with the Bank or the Data Protection Board of India.
- **Data Fiduciary Obligations:** The Bank must implement technical and organisational measures to ensure data security, appoint a DPO (as a Significant Data Fiduciary), maintain accuracy of data, and ensure erasure when the purpose of collection has been fulfilled.
- **Significant Data Fiduciary (SDF):** The central government may notify the Bank as a Significant Data Fiduciary based on the volume and sensitivity of data processed. SDFs are subject to additional obligations including mandatory DPO appointment, Data Protection Impact Assessments, and periodic audits.
- **Data Protection Board of India:** An independent body established under the DPDP Act to adjudicate complaints and impose penalties. Penalties for non-compliance may reach up to ₹250 crore per instance of breach.

4.2 RBI Guidelines and Master Directions

The Reserve Bank of India has issued extensive guidance on data protection, cybersecurity, and customer data governance that is directly applicable to the Bank's operations.

- **RBI Master Direction on Digital Payment Security Controls (2021):** Mandates strong authentication, encryption, and monitoring of all digital payment channels, including those handling UPI IDs, credit card numbers, debit card numbers, and bank account details.
- **RBI Guidelines on Storage of Payment System Data (2018):** Requires that all data related to payment systems — including end-to-end transaction details — must be stored only in India. This data localisation requirement applies to payment data processed by the Bank on behalf of any foreign payment system operator.
- **RBI Cyber Security Framework for Banks (2016) and subsequent circulars:** Mandates a board-approved cybersecurity policy, 24x7 security operations, incident response capabilities, and regular penetration testing of internet-facing systems.
- **RBI Master Direction on Information Technology Framework (2023):** Provides detailed requirements for IT governance, IT risk management, business continuity, and vendor management.

- **RBI Customer Service Guidelines:** Require that customer financial information — including loan account numbers, CIF numbers, and account balances — is shared only with the account holder or their authorised representative.

4.3 SEBI and IRDAI Compliance

To the extent the Bank or its subsidiaries engage in capital market activities or insurance distribution, the following additional obligations apply:

- **SEBI Cybersecurity and Cyber Resilience Framework:** Applicable to market infrastructure institutions and registered intermediaries. Requires implementation of data security controls, breach notification procedures, and periodic audits.
- **IRDAI Guidelines on Information and Cyber Security:** Applicable where the Bank distributes or administers insurance products involving health information, policy details, or customer identity data.

4.4 Information Technology Act, 2000 and IT (Amendment) Act, 2008

The IT Act and its amendments provide the foundational legal framework for electronic records, digital signatures, and data security in India. Key provisions include:

- **Section 43A:** Imposes liability on corporate entities that handle sensitive personal data or information negligently, causing wrongful loss or gain to any person.
- **Section 72A:** Creates criminal liability for disclosure of information, including financial information and personal data, without consent or in breach of a lawful contract.
- **IT (Reasonable Security Practices and Procedures and Sensitive Personal Data or Information) Rules, 2011:** Define 'sensitive personal data or information' (SPDI) to include passwords, financial information (bank account, credit card, debit card details), health information, biometrics, and sexual orientation. Mandate a privacy policy, consent for collection, and security practices aligned with ISO/IEC 27001.

4.5 Aadhaar and PMLA Compliance

- **Aadhaar (Targeted Delivery of Financial and Other Subsidies, Benefits and Services) Act, 2016:** Regulates the collection, storage, and use of Aadhaar numbers. The Bank may use Aadhaar-based e-KYC only through UIDAI-authorised channels. Aadhaar numbers must never be stored in plain text and must not be shared beyond what is strictly required for KYC verification.
- **Prevention of Money Laundering Act (PMLA), 2002 and PMLA Rules:** Require the Bank to collect, verify, and retain KYC documents — including Aadhaar, PAN, passport, and voter ID — for a minimum of five years after the customer relationship ends. Customer due diligence records are subject to law enforcement access under PMLA.

5. Data Classification

The Bank classifies all data it handles into four tiers. Classification determines the level of protection, access restrictions, and handling procedures that apply. All personnel are required to classify data correctly at the point of creation, collection, or receipt.

Classification	Description	Examples	Key Controls
PUBLIC	Information intentionally made available to the general public. Disclosure causes no harm.	Annual reports, branch locator, product brochures, interest rate schedules.	No special controls required.
INTERNAL	Information for internal use not publicly disclosed. Unauthorised external disclosure may cause reputational or operational harm.	Internal memos, process documents, organisational charts, training materials.	Standard access controls. Not for external sharing without approval.
CONFIDENTIAL	Sensitive business and personal data whose unauthorised disclosure could cause significant harm to the Bank, customers, or counterparties.	Customer account details, credit assessments, employee salary data, loan files, counterparty contracts.	Encrypt in transit and at rest. Role-based access. Masked in non-production environments.
RESTRICTED	Highest sensitivity tier. Compromise could result in regulatory sanctions, financial crime, identity theft, or serious personal harm.	Aadhaar numbers, PAN numbers, authentication credentials, payment card data, API keys, health records, biometric data.	Encrypt always. Strict need-to-know. Never in plain text. Full audit logging. Immediate revocation on suspected breach.

6. Roles and Responsibilities

The effective implementation of this policy requires clearly defined responsibilities across all levels of the organisation. The following describes the key roles and their corresponding data protection obligations.

6.1 Board and Senior Management

The Board Risk and Compliance Committee has ultimate oversight responsibility for the Bank's data protection framework. Senior Management is accountable for ensuring adequate resources, controls, and governance structures are in place. They approve this policy, review material incidents, and receive periodic reporting from the DPO. The Board approves the Bank's designation as a Data Fiduciary under the DPDP Act and its obligations as a Significant Data Fiduciary where so notified.

6.2 Chief Compliance Officer (CCO)

The CCO is responsible for overall governance of data protection compliance. The CCO ensures that business activities are conducted in line with the DPDP Act, RBI guidelines, and this policy, and provides regulatory interpretation to business teams.

6.3 Data Protection Officer (DPO)

The DPO operates independently and reports to the Board. Responsibilities include: monitoring compliance with the DPDP Act and applicable regulations; maintaining the Bank's Record of Processing Activities (ROPA); conducting Data Protection Impact Assessments (DPIAs) for high-risk activities; serving as contact for the Data Protection Board of India; managing Data Principal rights requests; and reporting material risks and incidents to Senior Management and the Board.

6.4 Compliance Officers

Compliance Officers across business lines support the DPO in monitoring day-to-day adherence to data protection obligations. They may review inspection findings and assessment records, and escalate concerns to the DPO. Compliance Officers do not have authority to modify security controls or override access restrictions.

6.5 Information Security Team

Responsible for implementing and maintaining technical controls to protect personal and sensitive data. This includes managing encryption standards, monitoring access to Restricted and Confidential data, and responding to security alerts. The Security Administrator role within this team holds elevated access privileges for configuring and managing security infrastructure, subject to enhanced oversight.

6.6 Platform Administrators

Platform Administrators are responsible for configuring and managing the Bank's enterprise technology platforms. They hold system-level access necessary to maintain platform availability and apply security configurations. Platform Administrators may not access, copy, or use personal customer data beyond what is strictly necessary for their platform maintenance responsibilities. All administrative actions are subject to logging and periodic review.

6.7 Architects and Technology Design Teams

Technology Architects define the Bank's data architecture and governance standards. They approve the design of systems that process personal or sensitive data and ensure that privacy-by-design principles are embedded into new technology solutions from the outset. Architects define governance standards and approve security designs before any new system is deployed into a production environment.

6.8 Data Engineers

Data Engineers build and maintain data pipelines, transformation logic, and analytical datasets. They may process approved datasets under defined data governance rules but must not access raw, unmasked customer data unless explicitly authorised for a specific purpose. Where data masking or pseudonymisation is in place, Data Engineers must operate within masked environments only.

6.9 AI Engineers and Analytics Teams

AI Engineers design, build, and maintain machine learning models and automated decision-support tools. They may work with approved, appropriately de-identified datasets under supervision of the AI Governance function. AI Engineers must not use personal customer data — including customer names, Aadhaar numbers, account numbers, or loan details — for model training without explicit approval from the DPO and AI Governance Officer. Model outputs that affect individual customers must be subject to human review before being acted upon.

6.10 Developers

Developers may process approved datasets for building and testing Bank applications. They may not access production customer data in development or testing environments without authorisation. Developers cannot modify enterprise security policies, override access controls, or deploy changes to production systems without following the Bank's approved change management process.

6.11 Auditors

Internal and external Auditors may review logs, reports, access records, and data processing documentation for compliance assessment purposes. Auditors operate with read-only access to relevant systems and records and may not modify production resources, alter audit logs, or take any action affecting the integrity of data or systems under review.

6.12 Third-Party Service Providers

All vendors, outsourced service providers, and technology partners who process personal data on behalf of the Bank are required to operate within the terms of a Data Processing Agreement (DPA). Third parties must demonstrate compliance with the DPDP Act and applicable RBI guidelines and are subject to periodic due diligence assessments.

7. Data Protection Principles

All processing of personal data by the Bank must conform to the following principles, which reflect the requirements of the DPDP Act, 2023, applicable RBI guidelines, and the Bank's own governance standards.

7.1 Lawfulness and Consent

The Bank processes personal data only where a valid legal basis exists under the DPDP Act. For most customer data — including names, mobile numbers, email addresses, date of birth, and Aadhaar numbers — this requires freely given, informed, and unambiguous consent obtained through a clear notice. Processing activities are documented and communicated to Data Principals through accessible privacy notices.

7.2 Purpose Limitation

Personal data collected for one purpose must not be used for an unrelated purpose without either a new lawful basis or the Data Principal's fresh consent. A customer's mobile number collected for transaction alerts must not be used for unsolicited marketing without separate consent. The Bank maintains a purpose registry as part of its Record of Processing Activities.

7.3 Data Minimisation

The Bank collects only the data strictly necessary for the stated purpose. Business owners and architects must consider whether a less data-intensive approach could achieve the same objective when designing new processes. Requests to collect or retain additional personal data fields must be justified and approved by the DPO.

7.4 Accuracy

The Bank maintains reasonable steps to ensure personal data held is accurate and up to date. Customers are provided with mechanisms to update their residential address, contact number, and email address through digital and branch channels. Data Principal rights to correction are facilitated within prescribed timeframes.

7.5 Storage Limitation and Data Erasure

Personal data is retained only for as long as is necessary to fulfil the purpose of collection or as required by law (e.g., PMLA's five-year retention requirement, RBI's payment data retention requirements). At the end of the retention period, data is securely deleted or anonymised. Where a Data Principal withdraws consent and no other legal basis exists for retention, the Bank erases the relevant data promptly.

7.6 Integrity and Confidentiality (Data Security)

All personal data — particularly Restricted data such as bank account numbers, credit card numbers, UPI IDs, MPIN, OTPs, API keys, and authentication tokens — must be protected against unauthorised access, loss, destruction, or alteration. Encryption, access controls, data masking, and continuous monitoring are the primary technical mechanisms to uphold this principle.

7.7 Accountability

The Bank can demonstrate compliance with the DPDP Act and applicable regulations at all times. The DPO bears primary responsibility for this accountability function, supported by Compliance, Information Security, and Legal teams. The Bank maintains a Record of Processing Activities (ROPA) and conducts periodic Data Protection Impact Assessments for high-risk processing activities.

8. Sensitive Data Handling

The Bank handles a wide variety of sensitive personal and financial information in the course of its operations. This section describes the categories of sensitive data processed by the Bank, the risks they present, and the specific controls that apply.

8.1 Identity Information

The Bank collects and verifies government-issued identity documents as part of its Know Your Customer (KYC) obligations under the PMLA, 2002, RBI Master Directions on KYC, and Aadhaar-based e-KYC guidelines. Identity documents processed include:

- **Aadhaar Number** — Used for e-KYC via UIDAI-authorized channels. Must never be stored in plain text. Aadhaar seeding and authentication must comply with the Aadhaar Act, 2016.
- **Permanent Account Number (PAN)** — Collected for tax compliance under the Income Tax Act and as a KYC document for high-value transactions.
- **Passport Number** — Collected for NRI and foreign national customers as primary identity proof.
- **Driving Licence** — Accepted as identity and address proof for individual customers.
- **Voter ID (EPIC)** — Accepted as identity and address proof.
- **GSTIN (Goods and Services Tax Identification Number)** — Collected for business customers for tax reporting and KYC purposes.

Identity information is classified as **Restricted**. It may only be accessed by authorized personnel with a verified need to fulfil KYC, fraud prevention, or legal compliance obligations. Aadhaar numbers must be tokenised or masked in all storage systems. Physical copies of identity documents must be managed under document security procedures.

8.2 Customer Personal Information

The following personal information categories are collected from customers and classified as **Confidential** or **Restricted** depending on the context of use:

- **Customer Name**
- **Email Address**
- **Phone Number / Mobile Number**
- **Date of Birth**
- **Residential and Communication Address**

Access to customer personal information systems is logged, and any bulk extraction of customer records requires explicit approval from the DPO and a documented business justification. Customer personal data must not be shared with marketing agencies or analytics vendors without a documented lawful basis and, where required, customer consent.

8.3 Financial Information

The Bank processes a broad range of financial data in its core banking activities. The following are classified as **Restricted** and subject to the most stringent controls:

- **Bank Account Number** — Core identifier for deposit and credit accounts.
- **IFSC Code** — Used in conjunction with account number for fund transfers.
- **Credit Card Number** — Subject to PCI DSS controls in addition to this policy.
- **Debit Card Number** — Subject to PCI DSS controls in addition to this policy.
- **UPI ID (Virtual Payment Address)** — Linked to the customer's mobile number and bank account.

- **Customer ID / CIF Number (Customer Information File)** — Unique identifier linking all customer accounts and relationships.
- **Loan Account Number** — Identifies credit facilities extended to customers.

Financial information must never be transmitted in plain text over unsecured channels and must not be included in unstructured communications such as email unless end-to-end encrypted. Access is restricted to personnel with a direct operational need and is reviewed quarterly. Payment card data must additionally comply with PCI DSS standards in all storage, processing, and transmission environments.

8.4 Authentication and Credential Information

Authentication information represents the most sensitive data category because its compromise directly enables fraud and unauthorised system access. The following are classified as **Restricted** and subject to the strictest controls:

- **Passwords and PINs** — Must be stored using industry-standard hashing (bcrypt, Argon2, or PBKDF2). Never stored in plain text.
- **MPIN (Mobile Banking PIN)** — Customer authentication credential for mobile banking. Never logged.
- **OTP (One-Time Password)** — Time-limited authentication token. Never stored after validation.
- **API Keys** — Used for machine-to-machine authentication. Must be rotated regularly and stored in a secrets management system.
- **Private Cryptographic Keys** — Must be stored in hardware security modules (HSMS) or approved key management systems.
- **Authentication Tokens and JWT Tokens** — Must have defined expiry. Must not contain unnecessary personal data in their payload.

Any suspected compromise of an authentication credential must be reported to the Information Security team immediately for revocation and forensic investigation. Authentication credentials must never be logged in application logs, error messages, or debug traces.

8.5 Health and Medical Information

Where the Bank facilitates insurance-linked financial products, health-tied credit products, or employee health benefit programmes, the following categories of health data may be processed:

- **Medical Records and Diagnoses** — Processed only where directly relevant to an insurance claim or credit underwriting assessment with explicit consent.
- **Health Insurance Policy Information** — Processed for the administration of group health policies for employees.

Health information is classified as **Restricted**. Access is restricted to authorised HR Benefits personnel and relevant insurance processing partners under a Data Processing Agreement. Health data must not be processed for any purpose other than the specific benefit or service for which it was provided, and must not be shared with any other business unit without DPO approval.

9. Access Control and Need-to-Know

9.1 Principle of Least Privilege

Access to personal and sensitive data systems is granted on the basis of the principle of least privilege — each individual receives the minimum access necessary to perform their defined role. No individual is granted access to data categories not directly relevant to their current job responsibilities. Access privileges are reviewed at a minimum every six months, and any change in role, department, or employment status triggers an immediate access review.

9.2 Need-to-Know

Beyond technical access rights, the Bank applies a need-to-know standard. Even where an individual has technical access to a system, they are expected to access only the specific records, reports, or datasets required for their assigned task. Accessing customer records without a documented business reason — even where technical access permits — constitutes a policy violation and may result in disciplinary action.

9.3 Access Approval and Documentation

All requests for access to Restricted or Confidential data systems must go through a documented approval workflow including a business justification, the approving manager's name, and the specific data categories to be accessed. Access approvals are stored for audit purposes for a minimum of five years.

9.4 Privileged Access Management

Platform Administrators, Security Administrators, and Cloud Administrators holding elevated technical privileges are subject to enhanced monitoring and additional approval requirements. Privileged access sessions are logged in full and reviewed regularly by the Audit and Information Security teams. Privileged accounts must not be used for routine, non-administrative tasks.

9.5 Periodic Access Review

The Information Security team conducts periodic access reviews in coordination with HR and business line managers. Stale accounts, unused access, and over-provisioned roles are decommissioned promptly. Results of access reviews are reported to the DPO and the Board Risk and Compliance Committee semi-annually.

10. Data Minimisation and Purpose Limitation

10.1 Collect Only What Is Necessary

Business teams must conduct a data necessity assessment before introducing any new data collection requirement. Each data field collected must be demonstrably necessary for the stated processing purpose. This assessment must be documented and submitted to the DPO for review where the data involved is sensitive in nature.

10.2 Define and Communicate Purpose

The purpose for which any personal data is collected must be defined before collection begins and communicated to the Data Principal through clear privacy notices. Any use of previously collected data for a new, different purpose requires either a new legal basis or renewed consent under the DPDP Act.

10.3 Data Masking and Redaction in Non-Production Environments

Production customer data — including Aadhaar numbers, account numbers, loan balances, and contact details — must not be used in development, testing, or analytical environments without first being masked or pseudonymised. Data Engineers and Developers working in non-production environments must operate exclusively with masked datasets. Where a document containing personal data must be shared externally for a limited purpose, sensitive fields not relevant to that purpose must be redacted before transmission.

10.4 Consent Withdrawal and Data Erasure

Where a Data Principal withdraws consent under Section 6 of the DPDP Act and no other lawful basis exists for continued retention, the Bank must erase the personal data within the timeframe prescribed by the Act and internal procedures. The DPO maintains a process for receiving, tracking, and actioning withdrawal of consent requests.

11. Cross-Border Data Transfers

The transfer of personal data outside India is subject to restrictions under the DPDP Act, 2023, and RBI data localisation requirements. The Bank takes a conservative approach to cross-border data flows and requires specific approval for any such transfer.

11.1 DPDP Act Restrictions

The DPDP Act, 2023 empowers the central government to restrict the transfer of personal data to specified countries or territories. The Bank must comply with any government notification restricting cross-border data transfers and must monitor this regulatory space closely. In the absence of a government restriction, transfers are permissible subject to the Bank ensuring adequate protections are in place at the destination.

11.2 RBI Data Localisation Requirements

RBI guidelines require that all data relating to payment systems — including end-to-end transaction data involving credit card numbers, debit card numbers, UPI IDs, and bank account details — must be stored exclusively within India. This requirement applies regardless of whether the Bank uses domestic or international technology service providers. Any mirroring or processing of payment data outside India requires prior RBI approval.

11.3 Transfer Approval Process

Any proposed transfer of personal or sensitive data outside India must be reviewed and approved by the DPO and Legal team before it is initiated. Approval must document the categories of data transferred, the recipient entity, the legal basis for transfer, the safeguards in place, and the applicable regulatory clearance.

11.4 Transfer Documentation

All approved cross-border data transfers must be recorded in the Bank's Record of Processing Activities (ROPA). This documentation is available for review by the Data Protection Board of India and the RBI upon request.

12. AI Governance and Responsible Use of Technology

The Bank increasingly uses automated systems, data analytics, and artificial intelligence to support its operations — including credit scoring, fraud detection, customer segmentation, and regulatory reporting. The use of such systems must be governed responsibly to ensure fairness, accountability, and protection of customer rights under the DPDP Act and RBI guidelines.

12.1 Human Oversight

Any AI-generated decision that materially affects a customer — such as a credit refusal, a fraud flag leading to account suspension, or a KYC determination — must be subject to human review before being acted upon. Fully automated decisions with significant customer impact are prohibited without a defined human escalation pathway. Under the DPDP Act, Data Principals have the right to object to certain automated processing.

12.2 Responsible AI and Fairness

AI systems must be designed and operated in a manner that is fair, explainable, and consistent with the Bank's obligations to customers and regulators. The AI Governance Officer is responsible for establishing and maintaining the Bank's AI ethics standards, aligned with ISO/IEC 42001 and the NIST AI Risk Management Framework (AI RMF).

12.3 AI Risk Assessment

Before any AI model is deployed in a production environment affecting customer data or regulatory processes, it must undergo a documented risk assessment covering model accuracy, bias testing, data quality, security, and regulatory compliance. This assessment is reviewed by the AI Governance Officer and approved by the Chief Risk Officer.

12.4 Secure AI Development

AI Engineers must follow secure development practices including: validation of model inputs to prevent prompt injection attacks; validation of model outputs before use in customer-facing or regulatory processes; use of approved, appropriately protected and masked datasets for model training; and documentation of data lineage for all training datasets.

12.5 Model Input and Output Validation

Systems that accept free-text or external inputs must implement controls to detect and prevent attempts to manipulate model behaviour through adversarial inputs or prompt injection techniques. Model outputs used to drive customer-impacting decisions must be validated for reasonableness before use. Anomalous or unexpected outputs must be flagged for human review.

12.6 Prohibited AI Practices

The Bank prohibits: using unmasked personal customer data — including Aadhaar numbers, PAN numbers, account numbers, or loan details — for AI model training without explicit DPO approval; deploying AI models in production without prior risk assessment and governance approval; using AI to make fully automated decisions that significantly and adversely affect customers without providing a right to human review; and using AI to process health or biometric information for purposes not disclosed in the Bank's privacy notices.

13. Monitoring, Audit, and Oversight

13.1 Audit Logging

The Bank maintains comprehensive audit logs for all access to systems containing personal or sensitive data. Audit logs capture: the identity of the individual or system accessing data; the date and time of access; the data category accessed; the action performed (view, modify, extract, delete); and the source system or application used. Audit logs for Restricted data systems are retained for a minimum of five years and must not be modified, deleted, or tampered with.

13.2 Continuous Monitoring

The Information Security team monitors access patterns and data processing activities on an ongoing basis to detect anomalies, unauthorised access, or potential data breaches. Automated alerts are configured to flag unusual patterns such as bulk data extractions, access from unrecognised locations, or access to high-sensitivity datasets outside business hours.

13.3 Auditor Access

Auditors — whether internal audit team members or external regulatory inspectors from the RBI, SEBI, or the Data Protection Board of India — may access audit logs, processing records, access control documentation, and system reports for compliance assessment. Auditors are granted read-only access and may not take any action that would alter records, modify system configurations, or affect the integrity of the data under review.

13.4 DPO Oversight

The DPO reviews audit reports quarterly and raises material concerns to Senior Management. The DPO also coordinates external audits and regulatory inspections, including those by the Data Protection Board of India and the RBI's IT examination team.

13.5 Regulatory Reporting

Where required by applicable law or regulation, the Bank submits periodic data protection and cybersecurity reports to the RBI, SEBI, and other relevant regulatory authorities. The DPO is responsible for coordinating these submissions and ensuring their accuracy and completeness.

14. Incident Management and Breach Notification

14.1 Definition of a Personal Data Breach

A personal data breach is any event involving the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data. This includes: unauthorised access to customer accounts or financial records; theft or loss of a device containing unencrypted customer data; inadvertent disclosure of customer financial information; ransomware or malware affecting systems storing personal data; or a vendor reporting that personal data shared by the Bank has been compromised.

14.2 Incident Reporting

All Bank employees and third-party partners must report suspected or confirmed data breaches to the Information Security team and the DPO immediately upon becoming aware. Delay in reporting a known breach is itself a policy violation and may attract regulatory sanction from the Data Protection Board of India.

14.3 Regulatory Notification

Under the DPDP Act, 2023, the Bank as a Data Fiduciary must notify the Data Protection Board of India and affected Data Principals in the event of a personal data breach in the manner and within the timeframe prescribed. Where RBI guidelines impose separate breach notification obligations — including for cybersecurity incidents and frauds — those reporting timelines are followed concurrently.

14.4 Post-Incident Review

Following resolution of a data breach, the Information Security and Compliance teams conduct a formal post-incident review to identify root causes, evaluate the adequacy of the Bank's response, and implement corrective measures. Findings are reported to Senior Management and the Board Risk and Compliance Committee.

15. Third-Party and Vendor Management

15.1 Vendor Due Diligence

Before engaging any third party that will process personal data on behalf of the Bank, the Procurement and Information Security teams must conduct a data protection due diligence assessment evaluating the vendor's security practices, their compliance with the DPDP Act and RBI guidelines, and their ability to meet the Bank's contractual requirements.

15.2 Data Processing Agreements

All third parties acting as Data Processors must enter into a Data Processing Agreement (DPA) with the Bank before any personal data is shared. The DPA must address: the categories of personal data being processed; the purpose and duration of processing; security and confidentiality obligations; restrictions on sub-processing; data breach notification obligations; data return or deletion upon termination; and the Bank's right to audit the vendor's data protection practices.

15.3 Ongoing Monitoring

The Compliance team conducts periodic reviews of vendor compliance with the DPA and applicable law. Material changes in a vendor's data processing practices must be reported to the Bank and approved by the DPO. Vendors with access to Restricted data are subject to annual security assessments.

16. Regulatory Compliance References

Framework / Standard	Applicability	Key Requirements for the Bank
DPDP Act, 2023	All India operations	Consent framework, Data Principal rights, DPO appointment, breach notification, Data Protection Board oversight.
IT Act, 2000 & SPDI Rules, 2011	All India operations	Sensitive personal data protection, privacy policy, security practices, liability for negligence.
RBI Cybersecurity Framework (2016+)	All banking operations	Board-approved cybersecurity policy, 24x7 SOC, incident reporting to RBI within prescribed timelines.
RBI Master Direction — Digital Payments (2021)	Digital payment channels	Strong authentication, encryption of payment data, fraud monitoring.
RBI Data Localisation (2018)	Payment system data	All payment data stored exclusively in India. No mirroring abroad without RBI approval.
RBI IT Framework (2023)	All banking operations	IT governance, IT risk management, vendor management, BCP/DR.
Aadhaar Act, 2016	KYC / e-KYC operations	Aadhaar-based authentication only via UIDAI channels. No plain-text storage of Aadhaar numbers.
PMLA, 2002 & KYC Master Direction	All customer-facing operations	KYC document collection, customer due diligence, 5-year retention post relationship end.
PCI DSS	Card payment processing	Encryption, tokenisation, and secure handling of credit and debit card data. Annual QSA audit.
ISO/IEC 27001	Enterprise-wide	Information security management system, risk assessment, controls framework.
ISO/IEC 42001	AI systems	AI management system, risk-based AI governance, documentation and monitoring.
NIST AI RMF	AI governance	AI risk identification, measurement, management, and governance framework.
SEBI Cyber Resilience Framework	Capital market activities	Data security controls, breach notification, periodic audits for market intermediaries.
IRDAI Cyber Security Guidelines	Insurance distribution	Security of health and insurance data; incident reporting to IRDAI.

17. Exceptions and Deviations

Any request to deviate from the requirements of this policy must be submitted in writing to the DPO and the Chief Compliance Officer. Requests must include: a clear description of the proposed deviation; the business justification; an assessment of the risks arising; proposed compensating controls; and the duration of the exception. Exceptions may only be granted by the DPO in consultation with the CCO and must be documented with a defined review date. No exception shall be granted that would place the Bank in breach of the DPDP Act, RBI guidelines, or any other applicable law.

18. Policy Review and Governance

This policy is reviewed annually, or earlier in the event of: material changes to the DPDP Act, RBI guidelines, or other applicable law; a significant data breach or regulatory enforcement action; introduction of new data processing activities or technologies; or changes to the Bank's corporate structure. All revisions are approved by the Board Risk and Compliance Committee before taking effect. Employees are notified of material changes and are required to confirm their understanding of the updated policy.

Appendix A — Data Classification Reference Table

Data Type	Classification	Examples	Key Handling Requirements
Government Identity Documents	RESTRICTED	Aadhaar Number, PAN Number, Passport Number, Driving Licence, Voter ID (EPIC), GSTIN	Tokenise/mask Aadhaar. Encrypt at rest and in transit. Authorised KYC personnel only.
Customer Personal Information	CONFIDENTIAL	Customer Name, Email Address, Phone Number, Date of Birth, Residential Address	Controlled access. Purpose-limited use. Masked in non-production environments.
Financial Account Data	RESTRICTED	Bank Account Number, IFSC Code, Credit Card Number, Debit Card Number, UPI ID, CIF Number, Loan Account Number	Encrypt always. Never transmit in plain text. PCI DSS controls for card data. Access restricted to operational need.
Authentication Credentials	RESTRICTED	Password, MPIN, OTP, API Keys, Private Keys, Authentication Tokens, JWT Tokens	Never store in plain text. Never log. Rotate regularly. Immediate revocation on suspected compromise.
Health and Medical Information	RESTRICTED	Medical Records, Health Insurance Policy Information, Treatment History	Strictly limited access. HR Benefits personnel only. No sharing without DPO approval.
Internal Business Information	INTERNAL	Memos, Process Documentation, Organisational Charts, Training Materials	Standard access controls. Not for external disclosure without approval.
Public Information	PUBLIC	Published Annual Reports, Product Brochures, Branch Locations, Interest Rate Schedules	No special handling required.

Appendix B — Regulatory Framework Comparison

Feature	DPDP Act, 2023	IT Act / SPDI Rules	RBI Frameworks
Primary Focus	Digital personal data privacy, consent, Data Principal rights	Sensitive personal data, electronic records, cybercrime	Banking cybersecurity, payment data, operational risk
Regulator	Data Protection Board of India	Ministry of Electronics & IT (MeitY)	Reserve Bank of India
DPO Required?	Yes, for Significant Data Fiduciaries	No (but privacy officer recommended)	CISO mandatory for scheduled banks
Consent Required?	Yes, for most processing	Yes, for SPDI collection	Implied for banking operations; explicit for data sharing
Data Localisation?	Government may restrict cross-border flows	No specific localisation mandate	Payment data must be stored only in India
Breach Notification?	Yes — to Data Protection Board & Data Principals	No explicit timeline; liability under S.43A	Yes — to RBI within prescribed timelines
Penalty / Fine	Up to ₹250 crore per instance	Compensation under S.43A; imprisonment under S.72A	Regulatory action, licence conditions, monetary penalties
Data Retention	Erase when purpose fulfilled or consent withdrawn	As per contractual or legal requirement	Payment data: as per RBI directions; KYC: 5 years (PMLA)

Appendix C — Glossary of Regulatory Bodies and Acts

Body / Act	Full Name	Role
DPDP Act, 2023	Digital Personal Data Protection Act, 2023	India's primary federal data privacy legislation governing digital personal data processing.
Data Protection Board	Data Protection Board of India	Independent adjudicatory body established under the DPDP Act to investigate complaints and impose penalties.
RBI	Reserve Bank of India	Central bank and financial regulator. Issues cybersecurity, KYC, and payment data guidelines applicable to all banks.
MeitY	Ministry of Electronics and Information Technology	Nodal ministry overseeing the IT Act, SPDI Rules, and implementation of the DPDP Act.
UIDAI	Unique Identification Authority of India	Statutory authority governing the Aadhaar biometric identification system. Authorises e-KYC channels.
SEBI	Securities and Exchange Board of India	Capital markets regulator. Issues cyber resilience frameworks for market intermediaries.
IRDAI	Insurance Regulatory and Development Authority of India	Insurance sector regulator. Issues cybersecurity and data protection guidelines for insurers and distributors.
PMLA	Prevention of Money Laundering Act, 2002	Anti-money laundering legislation mandating KYC document collection and five-year retention of customer due diligence records.
ISO/IEC 27001	International Standard for Information Security Management Systems	Global benchmark for information security controls. Referenced in SPDI Rules, 2011 as a recognised security practice.
ISO/IEC 42001	International Standard for AI Management Systems	Provides a framework for responsible AI development, deployment, and governance.
NIST AI RMF	NIST Artificial Intelligence Risk Management Framework	Voluntary US framework for AI risk identification, management, and governance. Adopted by the Bank as a reference standard.
PCI DSS	Payment Card Industry Data Security Standard	Global security standard governing the storage, processing, and transmission of credit and debit card data.

This document has been approved by the Board Risk and Compliance Committee and is effective as at the date stated on the cover page. Queries regarding interpretation or application of this policy should be directed to the Data Protection Officer at dpo@bharatviksabank.in

© 2026 Bharat Vikas Bank — INTERNAL DOCUMENT. NOT FOR EXTERNAL DISTRIBUTION.